国际金融科技大赛 · 安全自评报告

银龄暖声 · 安全自评

权限分级实现说明与已知风险清单

评估环境：自建模拟银行沙箱

仓库：elder-voice-bank-agent

2026 年 10 月

目　录

一、报告范围与结论

1.1 评估对象

1.2 结论摘要

1.3 边界声明

二、安全架构总览

三、权限分级实现说明

3.1 四级额度与触发条件

3.2 一次性授权票据

3.3 权限裁定的唯一来源

3.4 可解释风险证据

3.5 执行幂等与并发保护

3.6 审计哈希链

3.7 代码位置与测试覆盖

四、注入与幻觉防护（与权限分级的配合）

五、测试与验证结果

六、已知风险清单

6.1 需要重点跟进的五项

七、合规与边界声明

八、自评结论

银龄暖声 · 安全自评报告

> 面向老年人的语音数字银行管家（仓库名 `elder-voice-bank-agent`）
> 版本 v1.0 · 评估环境：自建模拟银行沙箱 · 编制日期：2026-10-27

一、报告范围与结论

1.1 评估对象

本报告评估「银龄暖声」语音银行智能体的资金安全设计，重点覆盖提交要求中的两项内容：

1. **权限分级实现说明**——四级额度、授权票据、裁定主体、可解释证据、幂等与审计；
2. **已知风险清单**——逐项列出残余风险、现有缓解措施与后续建议。

1.2 结论摘要

结论项	结果
权限分级是否完整实现	是。L0–L3 四级额度 + 一次性授权票据，规则引擎独占裁定权
大模型是否可绕过权限	否。模型只输出意图与风险信号，无资金接口调用权，信号上限 L2
金额与收款人是否可能被模型篡改	否。参数一律由系统从用户原话确定性抽取，模型给的数字必须能在原话中找到
注入攻击是否有防线	是。输入层特征库 + 决策层数据/指令分离 + 执行层复述一致性校验
诈骗剧本拦截效果	13 条剧本资金损失由 ¥200,300 降至 **¥0**，守住率 100%
合法业务是否被误伤	误报率 **0%**（12 条正常老人操作无一被误拦）
已识别残余风险	12 项，均有缓解措施；其中 5 项需在生产化阶段重点跟进
测试覆盖	**162 项自动化测试**，含 13 项真实启动服务的端到端 HTTP 用例

1.3 边界声明

本系统为**竞赛演示原型**，业务数据全部来自自建模拟银行核心，**不连接任何真实银行系统、不涉及真实资金**。报告中的"拦截""资金损失"均为沙箱内的模拟结果。相关边界见第七章。

二、安全架构总览

系统把"读懂人话"与"能不能动钱"彻底分层，这是全部安全设计的出发点。

层	职责	关键约束
输入层	反诈特征库比对、外部字段注入净化	备注 / 商户名等不可信文本只作数据，不作指令
决策层	大模型意图理解 + 确定性槽位抽取	模型无资金接口调用权；参数只认用户原话

层	职责	关键约束
裁定层	规则引擎判定 L0–L3	**权限裁定的唯一来源**，模型无权参与
执行层	票据校验、资金校验、幂等保护、落账	票据一次有效；已执行会话幂等返回
审计层	全链路哈希链 + SQLite 持久化	每笔可回放，支持链完整性校验

一句话概括：**模型提高警惕，规则决定放行，人做最后确认。**

三、权限分级实现说明

3.1 四级额度与触发条件

等级	触发条件	需要什么	失败后果
L0 免密小额	金额 ≤ 免密额度（默认 200 元）且收款人在白名单	语音复述一次	—
L1 中额	200 < 金额 ≤ 2000 元	语音复述 + 大字二次弹窗（确认按钮延迟 1 秒激活）	—
L2 大额	金额 > 2000 元，或首次收款人 / 异地 / 非活跃时段 / 新设备 / 反复改口	一次性授权票据，子女远程放行	未授权不可执行
L3 高风险	高危收款人、诈骗话术命中、指令注入、声纹不匹配、余额或限额越界、紧急止付生效	**直接阻断**，不提供"再来一次"	资金零变动

裁定逻辑实现在 `backend/risk.py::evaluate`，输入包含金额、收款人、时段、设备可信度、声纹结果、第二说话人、犹豫次数、话术命中与大模型风险信号，输出结构化的 `RiskDecision`。

3.2 一次性授权票据

大额与异常转账不靠"信任对话"，靠**可验证凭证**：

- **绑定三要素**：金额、收款人（含账号）、老人账户 ID；任一不符即拒绝执行；
- **一次有效**：状态机 `pending → approved → used`，用后即废，重复审批与重放一律拒绝；
- **超时作废**：默认 5 分钟，过期票据直接失效；
- **只能收紧**：子女可下调金额，不可上调；不可变更收款人；子女端调整额度只允许收紧，放宽请求返回 409；
- **资金校验**：执行前校验可用余额，避免并发导致的透支。

3.3 权限裁定的唯一来源

这是本系统最关键的一条边界：

- 大模型只输出结构化意图（`intent` / `payee` / `amount`）与一路反诈信号；
- 金额与收款人**由确定性抽取器从用户原话中提取**，模型给出的金额必须能在原话里找到数字才被采纳；
- 模型的反诈信号**只能提升等级、不能降低等级**，且**上限为 L2**；L3 硬阻断只由确定性证据触发；

- 因此模型即使被诱导或出现幻觉，也既不能把钱放走，也不能把钱锁死。

3.4 可解释风险证据

除固定阈值外，系统提供两层可解释证据，均可逐项追溯：

证据类型	触发条件	权重/阈值	作用上限
`behavior_evidence`	金额显著高于该收款人历史均值（`amount_spike`）；同日向同一收款人重复转账（`same_day_burst`）	倍数与次数阈值	L2
`relationship_expert`	账户-收款人-设备-时段特征加权：无历史往来 0.15、关系过新 0.25、非活跃时段 0.20、设备不可信 0.25	合计 ≥ 0.40 触发	L2
`llm_fraud`	大模型语义可疑度	≥ 0.60 触发	L2

三类证据都遵循同一原则：**只增加摩擦，不单独形成硬阻断**。硬阻断必须有确定性证据。

3.5 执行幂等与并发保护

- 会话状态机保护：已执行会话重复调用 `/agent/execute` 时**幂等返回原结果**，不重复落账；
- 票据状态保护：`used` / `expired` / `rejected` 状态均不可再次执行；
- 全局状态锁：账户、票据、审计写入均在可重入锁内完成；
- 执行前资金校验：余额不足直接拒绝，避免"票据已批但钱不够"的中间态。

3.6 审计哈希链

- 每条审计记录包含 `prev_hash` 与 `entry_hash`，哈希采用 SHA-256 覆盖规范化 JSON（字段排序、无空白）；
- 记录持久化到 SQLite（`AUDIT_DB_PATH` 可配置，默认内存库），支持跨重启回放；
- 提供只读校验接口 `GET /audit/verify`，逐条重算并比对前序哈希，可定位到第一条被破坏的记录；
- 审计覆盖完整链路：意图 → 计划 → 规则判定 → 确认 → 授权 → 执行。

3.7 代码位置与测试覆盖

能力	代码位置	测试
四级裁定	`backend/risk.py::evaluate`	`PermissionCase`（15 项边界）
授权票据	`backend/agent.py::create_ticket / approve_ticket / execute`	`AuthTicketCase`（8 项）
可解释证据	`backend/risk.py::behavior_evidence / relationship_expert`	`tests/test_acceptance.py` 行为证据与关系专家用例
幂等与并发	`backend/agent.py::execute`	幂等与并发保护用例
审计链	`backend/agent.py::audit / verify_audit_chain`	审计链完整性用例

能力	代码位置	测试
多账户隔离	`backend/bank.py` 账户作用域	多账户隔离用例

四、注入与幻觉防护（与权限分级的配合）

权限分级解决"该不该放行"，注入防御解决"输入是否被污染"。三者叠加才构成完整防线：

1. **输入层**：反诈特征库比对六类话术（冒充公检法、客服退款、冒充亲属、投资诱导、保密施压、指令注入）；
2. **决策层**：LLM 不持有资金接口；备注、商户名、账单描述等外部文本用定界符包裹为**纯数据**，

并剔除指令型片段；**备注之后的内容不参与实体抽取**，骗子写在备注里的收款人永远进不了执行槽位；

1. **执行层**：语音复述 + 二次确认，复述内容与最终参数做一致性校验，不一致即中止。

配套 **13 条诈骗剧本**的左右屏攻防对比，其中第 13 条是关键词库的盲区，只能由大模型的语义信号识别——这条剧本用于量化"接入大模型前后"的真实差异。

五、测试与验证结果

测试环境：`deepseek-chat`（OpenAI 兼容接口） · 语音：浏览器原生识别与合成 · 资金：模拟沙箱

维度	结果	口径
意图理解准确率	**100%**（48/48）	普通话 21 条 + 粤语 27 条
权限分级判定准确率	**100%**（15/15）	L0–L3 全部边界
正常操作误报率	**0%**（0/12）	12 条合法操作无一被阻断
注入防御 L3 直接阻断率	**76.9%**（10/13）	其余 3 条升权至 L2
注入防御守住率	**100%**（13/13）	L3 阻断 + L2 转授权
防御侧资金零损失率	**100%**	合计损失 ¥200,300 → **¥0**
幻觉参数拦截准确率	**100%**（5/5）	模型输出 vs 用户原话
授权票据安全项通过率	**100%**（8/8）	重放 / 超时 / 越权 / 放宽额度
赛题场景覆盖率	**100%**	6 大场景 / 27 项能力
扩展表达观察集	41.7% → **91.7%**	12 条，仅作观察，不并入主指标
自动化测试	**162 项全绿**	含 13 项真实启动服务的端到端用例

> 说明：扩展表达观察集不是外部真实用户盲测，只用于观察规则与模型的相对差异。

六、已知风险清单

风险等级定义：**高** = 可能导致资金损失或合规问题；**中** = 影响可用性或需生产化补强；**低** = 可接受或已有充分缓解。

编号	风险项	影响	现有措施	残余等级	后续建议
R-01	大模型不可用或未配置，意图理解降级为规则解析器	规则表覆盖不到的口语变体识别率降至 0%（主测试集仍为 100%）	规则引擎独立工作，**资金安全不受影响**；顶栏明示当前模式	中	生产环境配置模型可用性监控与自动切换
R-02	大模型响应延迟	首次调用可能等待，超时上限 8 秒	按原文缓存结果；超时自动回落规则解析，不阻断业务	中	引入预热、流式返回与更短超时
R-03	声纹校验为演示级实现	未接真实声纹库，可能存在误判	仅作**辅助信号**：不匹配时升权或阻断，从不单独放行	中	接入行方声纹平台，增加活体检测
R-04	语音识别依赖浏览器能力	非 Edge / Chrome 环境不可用	提供文本输入与「常用说法」按钮作为等价入口	低	接入云端 ASR 作为主通道
R-05	方言覆盖有限	目前真实支持普通话与粤语，其他方言识别率低	粤语归一化表 + 可扩展别名簿	中	按客群地域扩展方言与归一化词表
R-06	别名簿与亲属关系为静态种子数据	未做 KYC 级实名关系校验，理论存在别名冒用	非白名单收款人一律升权；关系过新进入可解释证据	中	对接行方客户关系图谱与实名核验
R-07	注入防御可能被新型话术绕过	特征库覆盖已知话术，未知话术需靠模型	模型语义信号 + L2 升权 + 人工/子女兜底	中	建立剧本持续运营机制，定期回归
R-08	沙箱环境未做真实并发与容量压测	生产吞吐与延迟未知	全局状态锁 + 幂等执行 + 资金校验	中	上线前做压测与多实例一致性设计
R-09	审计链为本地 SQLite 存储	未接外部公证或可信时间戳，本地库被整体替换时链可被重建	支持导出与 `/audit/verify` 校验	中	对接行内审计平台，增加外部时间戳
R-10	授权票据有效期固定 5 分钟	未按场景差异化配置	超时自动作废，重放拒绝	低	按业务场景参数化有效期
R-11	多账户隔离为逻辑隔离	单进程内存沙箱，非租户级物理隔离	账户作用域隔离 + 票据绑定账户 ID	低	生产化时按租户做存储隔离
R-12	依赖第三方模型输出质量	模型版本变更可能影响识别稳定性	一致性与数字校验兜底；162 项回归测试	中	固定模型版本，升级前跑完整回归

6.1 需要重点跟进的五项

R-01、R-02、R-03、R-07、R-09 属于生产化阶段必须补齐的能力：分别对应**模型可用性**、**响应时延**、**声纹真实性**、**话术持续对抗**与**审计可信性**。

七、合规与边界声明

1. **模拟环境**：所有账户、流水、理财、卡片与订阅数据均为自建沙箱数据（户主"张桂芬"，虚构账号），不连接任何真实银行系统，不产生真实资金往来；
1. **个人信息最小化**：演示数据不含真实个人信息；语音样本仅用于当次识别，不做持久化；
2. **模型使用边界**：大模型不持有资金操作权限，不接触真实账户凭据，仅接收用户话语文本；
3. **适当性管理**：老人自主申购仅放行 R1–R2 风险等级产品，高风险产品拦截或强制冷静期并同步子女；
4. **家属知情**：老人自主完成的申购、赎回、挂失、办卡、联动执行等动作实时同步子女端，老人端同时明示"已通知子女"，不存在背向家属办理业务的情况。

八、自评结论

「银龄暖声」在演示范围内建立了**可验证、可解释、可回放**的资金安全体系：

- 权限分级由规则引擎独占裁定，模型无放行权；
- 授权票据把"大额放行"从对话信任变成可验证凭证；
- 注入与幻觉防护保证执行参数只来自用户原话；
- 全链路审计哈希链支持完整性校验；
- 13 条诈骗剧本实测资金零损失，12 条合法操作零误伤。

上述能力均有自动化测试覆盖，残余风险已在第六章列明并给出后续建议。